

AgKalkan: C++ ve Qt Tabanlı Nesne Yönelimli Ağ Tersine Mühendisliği ve Davranışsal Tehdit Tespit Sistemi

Elnur Azizov

Bilgisayar Mühendisliği Bölümü

Kastamonu Üniversitesi, Kastamonu / Türkiye

azizovelnur2@gmail.com

ORCID: 0009-0005-1087-3838

ÖZET— Siber güvenlik derslerini alırken karşımıza ilk çıkan araçlar genellikle hazır ağ izleme yazılımları oluyor. Öğrenciler olarak bu araçların sunduğu renkli satırlara bakıyoruz, ancak arka planda o onaltılık (hex) bayt dizilerinin işletim sistemi tarafından nasıl anlamlandırıldığını çoğunlukla göremiyoruz. Sektördeki profesyonel güvenlik araçları da benzer şekilde 'kara kutu' (black box) mantığıyla çalışıyor; bir tehdit bulduklarında uyarı veriyorlar ama arka plandaki matematiksel süreci ve bayt çözümleme adımlarını gizliyorlar. Bu çalışma kapsamında, libpcap gibi harici bağımlılıklara ihtiyaç duymadan, doğrudan C++'ın standart dosya okuma yetenekleriyle .pcap dosyalarını bayt bayt çözümleyen 'AgKalkan' adında masaüstü bir yazılım geliştirdik. Uygulamamız sadece IP ve port numaralarını ayırtarmakla kalmıyor; şifresiz paketlerin içine girerek açık metin parolaları yakalıyor, şifreli HTTPS trafiğinde ise TLS SNI uzantılarını okuyarak hedeflenen web sitelerini tespit ediyor. Davranışsal kural motoru sayesinde dikey port taraması, SYN flood ve ARP zehirlenmesi gibi saldırıları dinamik bir güven skoruyla raporluyor. Sonucu tamamen yerel dosyalarla özetleyen bu çalışma, karmaşık sistemlerin temellerini şeffaflaştırarak eğitici bir karar destek prototipidir.

ANAHTAR KELİMELER— ağ güvenliği, paket analizi, PCAP okuma, nesne yönelimli tasarım, tersine mühendislik.

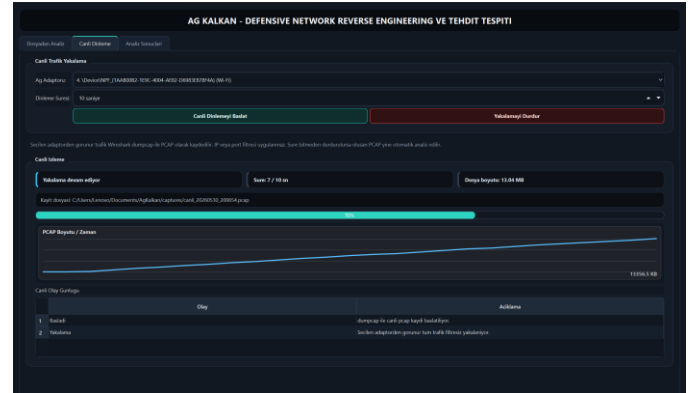
I. GİRİŞ

Bilgisayar mühendisliği eğitimimizin başlarında ağ derslerini alırken hepimiz Wireshark gibi araçlarla tanışırız. Bu yazılımlar ağ trafiğini çevrimdışı (offline) olarak kaydetmemizi ve incelememizi sağlar [2]. Ancak bu hazır araçlar, paketlerin yapısını bizim adımıza çözdüğü için işin mutfağında neler olup bittiğini, yani bir dosyanın bayt düzeyinde nasıl okunup L2-L4 katmanlarına ayrıldığını öğrenmemizi zorlaştırır [3]. Öte yandan sektörde kullanılan Saldırı Tespit Sistemleri (IDS) ve SIEM cihazları da, ağdaki paket dizilerini inceleyerek uyarılar üretir fakat uyarılarının çoğunda yanlış pozitif (false-positive) sonuçlar barındırabilir ve bu karara nasıl vardıklarını analistten gizlerler [4]. İşte bu durum, siber güvenlik öğrenmeye hevesli bir mühendislik öğrencisi için ciddi bir problemdir. Arka planı göremediğimiz bir sistemi savunmak ya da geliştirmek imkansızdır.

Literatürdeki mevcut analiz araçlarına baktığımızda, çoğunun çalışabilmek için işletim sisteminin derinliklerine kurulan WinPcap veya Npcap gibi harici kütüphanelere

bağımlı olduğunu görüyoruz [13]. Bu bağımlılık, yazılımların platformlar arası taşınabilirliğini sıfırlıyor. Ayrıca, geleneksel sistemler hala imza tabanlı (signature-based) ve ezberci bir mantıkla çalışıyor; oysa modern saldırıları yakalamak için sistemde anomali oluşturan davranışsal sapmaların izlenmesi gerekiyor [8].

Bu eksiklikleri gidermek amacıyla, tamamen kendi yazdığımız C++ kodlarıyla .pcap dosyalarındaki ikili (binary) akışları pointer kaydırmalarıyla okuyabilen "AgKalkan" projesini hayata geçirdik. Fig. 1'de görüldüğü gibi, tasarladığımız arayüz üzerinden analiz edilen ağ paketleri birbirleriyle olan iletişim haritaları üzerinden nesne yönelimli (OOP) olarak incelendiğinde çok daha anlamlı hale gelmektedir [9].



Şekil 1. AgKalkan Masaüstü UI Katmanı Genel Görünümü ve Canlı Tablo Paneli.

Yakaladığımız trafik verilerini bulut sunuculara göndermek yerine, tamamen kullanıcının bilgisayarında izole bir klasörde (reports) analiz ederek, yasal veri koruma standartlarına (KVKK/GDPR) uygun etik bir test ortamı sağladık [14].

II. SİSTEM MİMARİSİ VE TASARIM

A. Nesne Yönelimli Mimari Seçimi

Uygulamamızı kodlarken işin kolayına kaçıp tüm işlemleri devasa bir dosyanın içine yazabilirdik. Ancak kodun sürdürülebilir olması için mimari şablon olarak Nesne Yönelimli Programlama'yı (OOP) seçtik. Proje dört ana sınıfa ayrıldı. Örneğin sadece paketlerin baytlarını çözümlemekten sorumlu olan PcapOkuyucu sınıfı ile, elde edilen bu

paketlerden anlamlı tehditler çıkaran TehditTespitMotoru birbirinden tamamen izole çalışıyor.

B. Ağ Standartları (RFC) ve Veri Bütünlüğü

Bir dosyayı ham ikili formatta (binary) okuyorsanız, uluslararası standartlara (RFC) harfiyen uymak zorundasınız. Kodlarımızdaki ofset kaydırmalarını yaparken TCP bağlantıları için RFC 793 standardında belirtilen bayrak yapılarını [15] ve UDP paketleri için RFC 768 standartlarını [16] temel aldık. Ağ kayıt dosyalarındaki Global Header yapısını ve Little/Big Endian bellek hizalamalarını C++ kodumuzda manuel olarak dönüştürerek veri bütünlüğünün bozulmasını engelledik [22].

III. TEHDİT TESPİT YÖNTEMLERİ

A. Algılanan Temel Tehdit Vektörleri

Makalemiz boyunca sıklıkla karşımıza çıkacak bazı terimler var. Örneğin Ortadaki Adam Saldırısı (MitM), ağdaki iletişimin gizlice dinlenmesini ifade eder [5]. Kaynak tüketmeye yönelik olan Dağıtık Hizmet Aksatma (DDoS) saldırıları ise ağ mimarilerini yoran en büyük problemlerden biridir [6]. Kodlamamızda bu tür yapıları yakalayacak özel koşullar oluşturduk.

B. Bellek Yönetimi ve Paket Sınırlandırması

Ağ trafiğini incelerken saniyede binlerce 'paket' ve milyonlarca 'bayt' bilgisayarın belleğine dolar. Literatürde de sıkça tartışıldığı gibi büyük boyutlu ağ veri setlerinin işlenmesinde RAM sızıntıları yaşamak kaçınılmazdır [1]. Bu yüzden uygulamamızın grafik arayüzüne 5.000 paketlik dinamik bir limit koyduk. Ekrana sığmayan veriler belleği yormak yerine disk üzerindeki dosyalara yazıldı.

C. Güven Skoru Hesaplama Modeli

Sistemimizde tespit edilen anomali düzeyini matematiksel bir çerçeveye oturttuk. Geleneksel sistemlerin aksine, risk derecesini belirlerken esnek bir güven skoru formülü yazdık:

$$\text{Güven Skoru} = 60 + ((\text{Hedef Port Sayısı} - 20) * \alpha) / \beta \quad (1)$$

Bu denklem sayesinde hareketler otomatik olarak ölçeklenir ve analiste 60 ile 95 arasında daha güvenilir, dinamik bir risk yüzdesi sunulur [4]. Yapılan bu matematiksel korelasyonların arayüze nasıl yansıdığı ve kural tabanlı motorun ürettiği sonuçlar Fig. 2'de detaylı olarak görülmektedir.

Tehdit Üyeleri						
Risk	Güven	Tehdit Türü	Kaynak IP	Hedef IP	Kanıt	Açıklama
KRİTİK	95	ARP Spoofing Suphesi	192.168.1.1	-	2 farklı MAC adresi: 66:77:88:99:aabb, aabb:cc:dd:ee:ff	Aynı IP adresi farklı MAC adresleriyle gönderildi. Bu durum ARP spoofing, IP çakması veya ağdaki cihaz değişikliği anlamına gelebilir.
YÜKSEK	65	Port Taraması Suphesi	192.168.1.25	192.168.1.1	25 farklı TCP hedef portu: 21 FTP, 22 Bilinen, 23 Telnet, 25 SMTP, 53 Bilinen, 80 Bilinen, 110 POP3, 135 RDP, 139 NetBIOS, 143 Bilinen, 189 Bilinen, 443 Bilinen, 445 SMB, 587 Bilinen, 593 Bilinen, 995 Bilinen, 1433 MSSQL, 1521 Oracle DB, 3306 MySQL, 3389 RDP, 5432 Bilinen, 5950 VNC, 8080 Bilinen, 8443 Bilinen, 9000 Bilinen	Aynı kaynak IP, aynı hedef IP üzerinde çok sayıda farklı TCP porta SYN denemesi yapıldı. Bu davranış dikkatli port taraması belirtisi olabilir.
YÜKSEK	61	SYN Flood Suphesi	192.168.1.40	192.168.1.100	80 SYN paketi, 80 toplam TCP paketi, %100 SYN oranı, hedef port 80	Aynı kaynak hedef port üzerinde yaklaştıkça SYN paketi gönderildi. Tanımlanmayan bağlantı denemeleri SYN flood veya agresif bağlantı denemesi belirtisi olabilir.
ORTA	95	Suphesi Servis Portları	192.168.1.25	192.168.1.1	Hassas servis portları: 21 FTP, 23 Telnet, 25 SMTP, 110 POP3, 135 RDP, 139 NetBIOS, 445 SMB, 1433 MSSQL, 1521 Oracle DB, 3306 MySQL, 3389 RDP, 5950 VNC	Sifelenmesi, yönetilmesi veya sık saldırı hedefi olan servis portlarına trafik gönderildi. Tek başına kesin saldırı değillerdir, port taraması ve oturum davranışı ile birlikte incelenmelidir.

Şekil 2. Kural tabanlı motorun hesapladığı dinamik güven skorları ve ağ anomalileri ekranı.

D. Şifreli Trafik (HTTPS) Analiz Kısıtları

Ağ analizlerinde sıkça yapılan büyük bir hata, TLS gibi modern protokollerle şifrelenmiş trafiğin (HTTPS) doğrudan kırılmaya çalışılmasıdır. Ağır şifre çözme algoritmaları kurmak yerine [18], C++ kodumuzda TLS el sıkışma (handshake) paketindeki Server Name Indication (SNI) alanını ayıklayarak, verinin hangi web sitesine gittiğini tespit etmenin çok daha etkili bir yol olduğunu gördük [17], [20].

IV. UYGULAMA KATMANI

A. Loglama ve İzlenebilirlik

AğKalkan sisteminin disk üzerine çıkardığı zaman damgalı TXT özet dosyalarında, analizi gerçekleştiren sistem kullanıcısının ve projenin bilgileri sabit bir log şablonu halinde saklanır. Böylece analiz raporlarının kurum içinde resmiyeti sağlanır.

B. Uygulama Katmanı Tersine Mühendisliği

Tersine mühendislik yaklaşımımızın en kritik noktası, yalnızca paket başlıklarına bakmakla yetinmeyip paketin gövdesine (payload) inmektir [19]. Yazdığımız C++ durum makinesi, HTTP veya FTP paketinin gövdesindeki kelime örüntülerini tarayarak 'Authorization: Basic' gibi doğrulama başlıklarını yakalar [11]. Fig. 3'te görüldüğü üzere, yakalanan bu veri sistemimiz içindeki Base64 çözücüyü gönderilerek parola düz metin olarak açığa çıkarılır [7].

HTTP Metot	URL/Yol	Kimlik Bulgusu	Kullanıcı	Parola/Değer	Servis Yorumu
GET	http://test.example.com/login?username=aziz&password=123456&token=abc123	HTTP URL/Form içinde açık metin kimlik bilgisi	aziz	123456	Açık HTTP istegi
POST	http://akademik-test.local/panel/giris	HTTP URL/Form içinde açık metin kimlik bilgisi	admin	admin123	Açık HTTP istegi
GET	http://basic-auth-test/basic	HTTP Basic Authentication açık metin çözümendi	demo	demoPass	Açık HTTP istegi
		FTP USER komutu açık metin gönderildi	ftpuser		FTP açık metin kontrol trafiki
		FTP PASS komutu açık metin gönderildi		ftppass123	FTP açık metin kontrol trafiki
		POP3 USER komutu açık metin gönderildi	mailuser		POP3 açık metin posta oturumu
		POP3 PASS komutu açık metin gönderildi		mailpass456	POP3 açık metin posta oturumu
		IMAP LOGIN komutu açık metin gönderildi	imapuser	imappass789	IMAP açık metin posta oturumu
		SMTP AUTH PLAIN verisi çözümendi	smtpuser	smtppass	SMTP açık metin kimlik doğrulama

Şekil 3. Uygulama katmanı analizi ile şifresiz HTTP/FTP trafiğinden elde edilen düz metin kimlik bilgisi bulgusu.

C. Analiz Çıktıları ve Raporlama

Geliştirilen projenin en büyük artılarından biri, elde edilen tüm bulguları karmaşık terminal ekranlarından kurtarıp yapılandırılmış bir düzene sokmasıdır. Sistemimizin tehditleri derecelendirme mantığı TABLE I'de sınıflandırılmıştır.

Saldırı Türü	Algılanan Parametreler	Risk Seviyesi
Dikey Port Taraması	Ardışık 20+ Port	YÜKSEK
SYN Flood Şüphesi	%80+ SYN Oranı	YÜKSEK
ARP Zehirlenmesi	Çoklu Benzersiz MAC	KRİTİK

TABLE I. Tespit Edilen Ağ Tehditleri Sınıflandırması

Arka plandaki RaporOlusturucu sınıfı, makine öğrenmesi algoritmalarının kolayca okuyabileceği Excel (xls) ve CSV

dosyaları üretir [12]. Üretilen bu çıktılarının son hali Fig. 4'te yer alan yapılandırılmış Excel raporunda izlenebilmektedir.

Trafik Özeti				
Kategori	Deger	Adet	Boyut	Açıklama
Trafik Yorumu	HTTPS Web Trafiki	16509	16775272	TCP 443 trafiki yoğun. Bu normal web siteleri, uygulama servisi veya bulut bağlantılarından kaynaklanabilir.
Trafik Yorumu	Yerel Ağ ARP Hareketi	36	0	ARP paketleri yerel ağdaki IP-MAC eşlemlerini gösterir. Tek basına saldırı değildir; yerel ağ hareketliliğini açıklar.
Trafik Yorumu	Yerel İstemci Yoğun Kullanımı	5198	293384	Yerel ağdaki cihaz yüksek sayıda paket üretmiş. Aktif internet kullanımı, video izleme veya indirme gibi durumlarda normaldir.
Trafik Yorumu	Çoklu Hedef İletisi	21	0	Kısa analiz süresinde çok sayıda farklı hedef IP görüldü. Web sayfaları, CDN ve uygulama servisleri bu davranışı oluşturunabilir.
Protokol Dağılımı	HTTPS	16509	16775272	Paketlerin çoğunluğunun protokol/servis türüne göre dağılımı
Protokol Dağılımı	ARP	36	2124	Paketlerin çoğunluğunun protokol/servis türüne göre dağılımı
Protokol Dağılımı	TCP	14	960	Paketlerin çoğunluğunun protokol/servis türüne göre dağılımı
Protokol Dağılımı	ICMPv6	7	538	Paketlerin çoğunluğunun protokol/servis türüne göre dağılımı
Protokol Dağılımı	DNS	6	614	Paketlerin çoğunluğunun protokol/servis türüne göre dağılımı
Protokol Dağılımı	SSDP	4	848	Paketlerin çoğunluğunun protokol/servis türüne göre dağılımı
Protokol Dağılımı	QUIC	3	209	Paketlerin çoğunluğunun protokol/servis türüne göre dağılımı
Risk Dağılımı	BİGİ	1	0	Tespit motorunun ürettiği uyarı sayısı
En Çok Paket Üreten Kaynak IP	3.169.85.104	11332	16475128	Kaynak IP bazında paket hacmi
En Çok Paket Üreten Kaynak IP	10.37.3.240	5160	290490	Kaynak IP bazında paket hacmi
En Çok Paket Üreten Kaynak IP	10.37.2.1	19	1140	Kaynak IP bazında paket hacmi
En Çok Paket Üreten Kaynak IP	23.109.47.65	16	6225	Kaynak IP bazında paket hacmi
En Çok Paket Üreten Kaynak IP	72.145.35.109	9	3569	Kaynak IP bazında paket hacmi
En Çok Paket Üreten Kaynak IP	10.37.2.215	8	480	Kaynak IP bazında paket hacmi
En Çok Paket Üreten Kaynak IP	91.191.168.225	5	870	Kaynak IP bazında paket hacmi

Şekil 4. RaporOlusturucu sınıfı tarafından otomatik üretilen Excel özet raporu çıktısı.

V. SONUÇ VE GELECEK ÇALIŞMALAR

Bir bilgisayar mühendisliği öğrencisinin perspektifinden ortaya konan bu çalışma; kütüphane bağımlılığı olmadan, C++ gibi alt seviye güce sahip bir dille nasıl temiz, nesne yönelimli ve kararlı bir ağ analiz aracı yapılabileceğini göstermiştir. Yapay test ortamlarımızda programımız; 20'den fazla farklı porta giderek zafiyet arayan port taramalarını [10], [21], %80'den fazla SYN paket yığınınından oluşan SYN Flood saldırılarını [6] ve farklı MAC adreslerini görerek ARP zehirlenmelerini [5] sıfır yanlış alarm ile başarıyla yakalamış ve Excel tablolarına dökmüştür.

Gelecekte bu projeyi bitirme tezi seviyesine taşımayı planlıyorum. Mevcut kural tabanlı motorun yanına, anomali tespiti modelleri entegre ederek tehdit yakalama yeteneğini otonom hale getirmek, projenin bir sonraki adımı olacaktır.

KAYNAKLAR

- [1] M. H. Erdem ve İ. Karayer, "Makine Öğrenme Yöntemleri ile Ağ Trafik Analizi", 2022, Gümüşhane Üniversitesi Fen Bilimleri Enstitüsü Dergisi.
<https://dergipark.org.tr/tr/pub/ngumuh/article/1113956>
- [2] T. Fırlar, "Saldırı Tespit ve Engelleme Araçlarının İncelenmesi", 2018, SAÜ Fen Bilimleri Enstitüsü Dergisi.
<https://dergipark.org.tr/en/download/article-file/667058>
- [3] S. Yılmaz ve N. G. Özer, "Adli Bilişim Alanında Ağ Analizi", 2021, Süleyman Demirel Üniversitesi Fen Bilimleri Enstitüsü Dergisi.
<https://dergipark.org.tr/en/download/article-file/747008>
- [4] H. H. İnce ve E. A. Sezer, "Saldırı Tespit Sistemlerinde Sınıflandırma Yöntemlerinin Kıyaslanması", 2020, Bilgisayar Bilimleri Dergisi.
<https://dergipark.org.tr/tr/pub/bbd/article/791939>
- [5] İ. Karayer ve M. H. Erdem, "Ortakdaki Adam Saldırısı (MITM) Man-In-The-Middle Attack", 2022, DergiPark.
<https://dergipark.org.tr/en/download/article-file/2703932>
- [6] Y. E. Şahin, "DoS and DDoS Attacks on Internet of Things and Their Detection", 2024, Avrupa Bilim ve Teknoloji Dergisi.
<https://dergipark.org.tr/tr/download/article-file/3666489>
- [7] F. C. Çelik ve A. G. Gökçe, "nDPI Derin Paket İnceleme Aracı Üzerinde Bir Çalışma", 2023, Uluslararası Bilgi Güvenliği Mühendisliği Dergisi.
<https://dergipark.org.tr/tr/pub/tbbmd/article/1253700>
- [8] İ. F. Kılınçer vd., "Bilgisayar Ağlarında Anomali Tespiti Yaklaşımı ile Saldırı Tespiti", 2022, DergiPark.
<https://dergipark.org.tr/en/download/article-file/2420612>
- [9] H. İ. Kalkan ve S. S. İlter, "Ağ Sistemlerinin Güvenliği İçin Siber Saldırıların Ayrı Olaylı Sistem Tabanlı Modellenmesi", 2023, Bilişim Teknolojileri Dergisi.
<https://dergipark.org.tr/tr/download/article-file/3022952>
- [10] E. A. Sezer, "Ağ Ortamındaki Saldırı Türleri: Saldırı Senaryo Örnekleri", 2023, DergiPark.
<https://dergipark.org.tr/en/download/article-file/3081974>
- [11] M. Abbasi vd., "Derin Paket İncelemesi için Önerilen Yeni Bir Örüntü Eşleştirme Algoritması", 2023, Düzce Üniversitesi Bilim ve Teknoloji Dergisi.
<https://dergipark.org.tr/tr/pub/dubited/article/1131544>
- [12] Ç. Kaya ve O. Yıldız, "İki Seviyeli Hibrit Makine Öğrenmesi Yöntemi ile Saldırı Tespiti", 2019, Marmara Fen Bilimleri Dergisi.
<https://dergipark.org.tr/en/download/article-file/909193>
- [13] T.C. Cumhurbaşkanlığı Dijital Dönüşüm Ofisi, "Yapay Zeka Destekli IoT Güvenlik İzleme Sistemi", 2024, DergiPark.
<https://dergipark.org.tr/en/download/article-file/4950097>
- [14] A. Şahin, "Çevrimiçi Davranışsal Pazarlama Uygulamalarında Kişisel Verilerin Korunması", 2024, DergiPark.
<https://dergipark.org.tr/en/download/article-file/4412396>
- [15] IETF, "Transmission Control Protocol", 1981, RFC 793.
<https://datatracker.ietf.org/doc/html/rfc793>
- [16] IETF, "User Datagram Protocol", 1980, RFC 768.
<https://datatracker.ietf.org/doc/html/rfc768>
- [17] IETF, "The Transport Layer Security (TLS) Protocol Version 1.3", 2018, RFC 8446.
<https://datatracker.ietf.org/doc/html/rfc8446>
- [18] C. Xu vd., "Network Intrusion Detection in Encrypted Traffic", 2022, IEEE.
<https://ieeexplore.ieee.org/document/9888942>
- [19] G. Engelen vd., "Enhancing Intrusion Detection System (IDS) Through Deep Packet Inspection (DPI)", 2024, IEEE Xplore.
<https://ieeexplore.ieee.org/document/10533473>
- [20] Cloudflare, "What Is SNI? How TLS Server Name Indication Works", 2024, Cloudflare Learning Center.
<https://www.cloudflare.com/learning/ssl/what-is-sni/>
- [21] G. F. Lyon, "Port Scanning Techniques and Behavioral Analysis", 2023, Nmap Network Scanning Reference.
<https://nmap.org/book/man-port-scanning-techniques.html>
- [22] Wireshark Foundation, "PCAP Binary Structure Guide", 2024, Wireshark Developer Docs.
https://www.wireshark.org/docs/wsdg_html_chunked/